



Инфосистемы
Джет

Инструменты и процессы безопасной разработки: с чего начать и как развивать

Антон Конопак

Центр информационной безопасности
ae.konopak@jet.su

2026

ЧТО ТАКОЕ DESVECOPS



ЧТО ТАКОЕ DESVECOPS



Dev

Development

Ops

Operations

ЧТО ТАКОЕ DESVECOPS



Dev

Development

Sec

Security

Ops

Operations



DevSecOps (DSO) — подход (набор практик), дополняющий практики DevOps.

Он подразумевает не только тесное взаимодействие команд разработки и эксплуатации, но и применение лучших практик безопасности на всех этапах жизненного цикла программного обеспечения.

Какие состояния есть у приложения

A small yellow square icon located at the top left of the first box.

1

Разработка

A small yellow square icon located at the top left of the second box.

2

Тестирование

A small yellow square icon located at the top left of the third box.

3

Функционирование

Важные моменты

A small yellow square icon located at the top left of the first text block.

Регресс, функциональные и другие «НЕ» ИБ-тестирования приложений не рассматривается в этом докладе.

A small yellow square icon located at the top left of the second text block.

Термины «приложение», «ПО», «софт», «application», «app» — это все это одно и то же.



Инфосистемы
Джет

DevSec

Разработка приложения

Разработка бывает разная



Комплектность и «жесткость» требований зависят от типа разработки

IN-HOUSE

для себя

НА ЗАКАЗ

для конкретного
клиента

MASS MARKET

для любого числа
пользователей

Если просто



РАЗРАБОТЧИКИ
пишут софт

ДОСТАВКА

Софт где-то собирается
из исходного кода
и публикуется

ПОТРЕБИТЕЛИ
используют софт

Чуть больше деталей



Что-то я создаю



Что-то я заимствую
для создания



Где-то я храню
наработки



Что-то
автоматизирует
сборку ПО



Что-то я передаю
клиенту



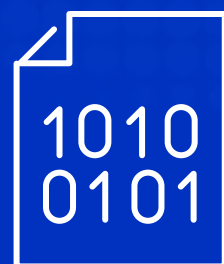
Что-то
использует
клиент

Чуть больше деталей



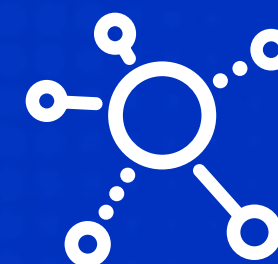
Что-то я создаю

Исходный код



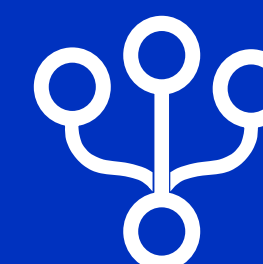
Что-то я заимствую
для создания

Зависимости



Где-то я храню
наработки

Система контроля
версий (VCS)



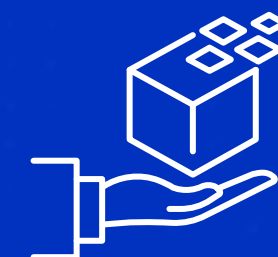
Что-то
автоматизирует
сборку ПО

Система непрерывной
сборки (CI)



Что-то я передаю
клиенту

Артефакт и реестр
(registry)

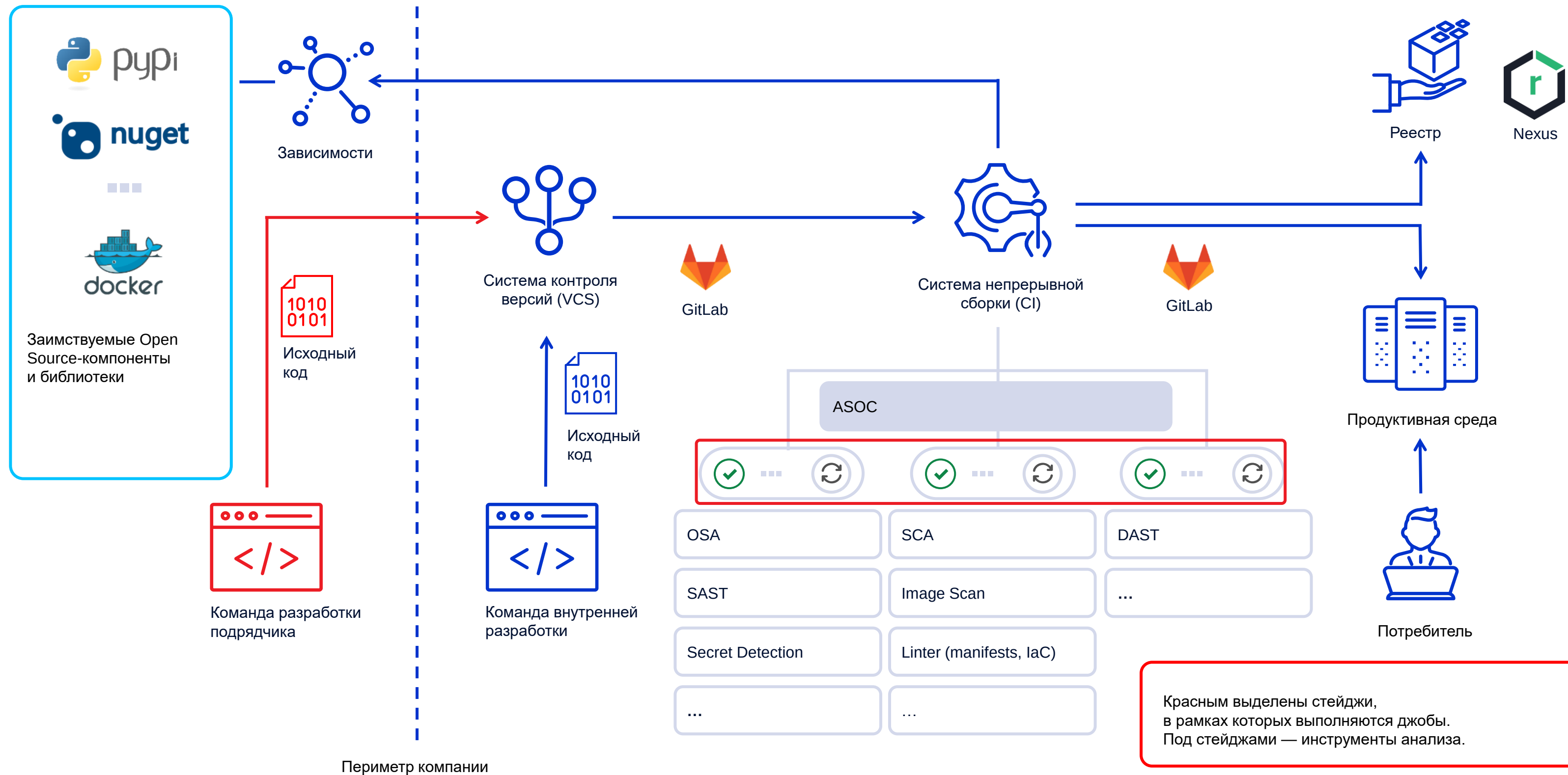


Что-то
использует
клиент

Приложение



Процесс разработки приложения. DevSec



Зачем нужен DEVSEC



ЗАДАЧИ DEVSEC:

анализ кода и защита разрабатываемого ПО до его запуска в продуктив

DevSec — это, по сути, безопасная разработка.
Использование инструментов DevSec значительно экономит время
и деньги компании, а также минимизирует риски ИБ.

ПРИМЕР «ОТ ПРОТИВНОГО»:

Уязвимости не были
обнаружены на этапе
разработки приложения

Заведомо уязвимое
приложение было
выпущено в продуктив

Мошенник проэксплуатировал уязвимости,
украл данные / деньги или углубился
за периметр компании



Инфосистемы
Джет

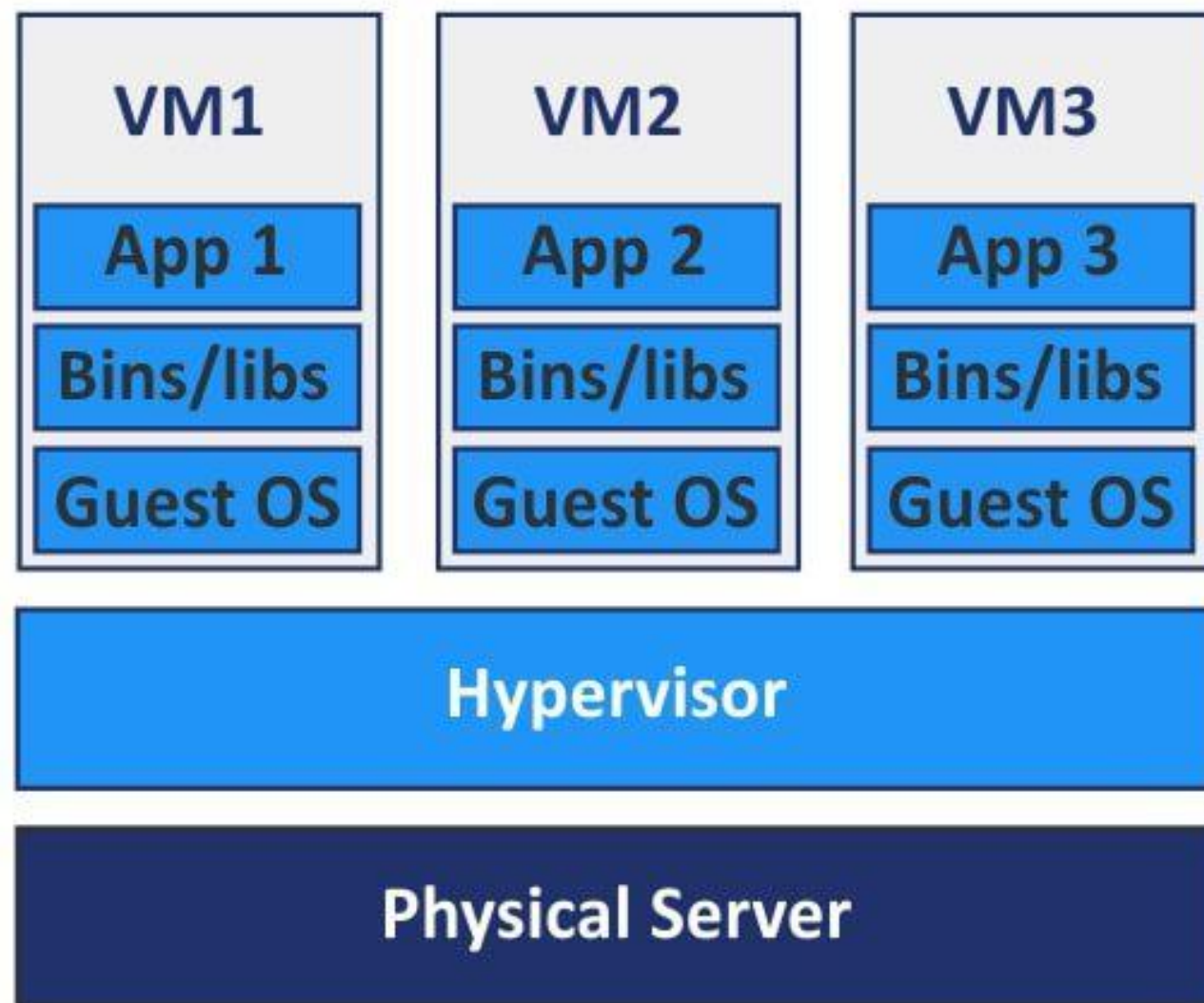
SecOps

Функционирование приложения

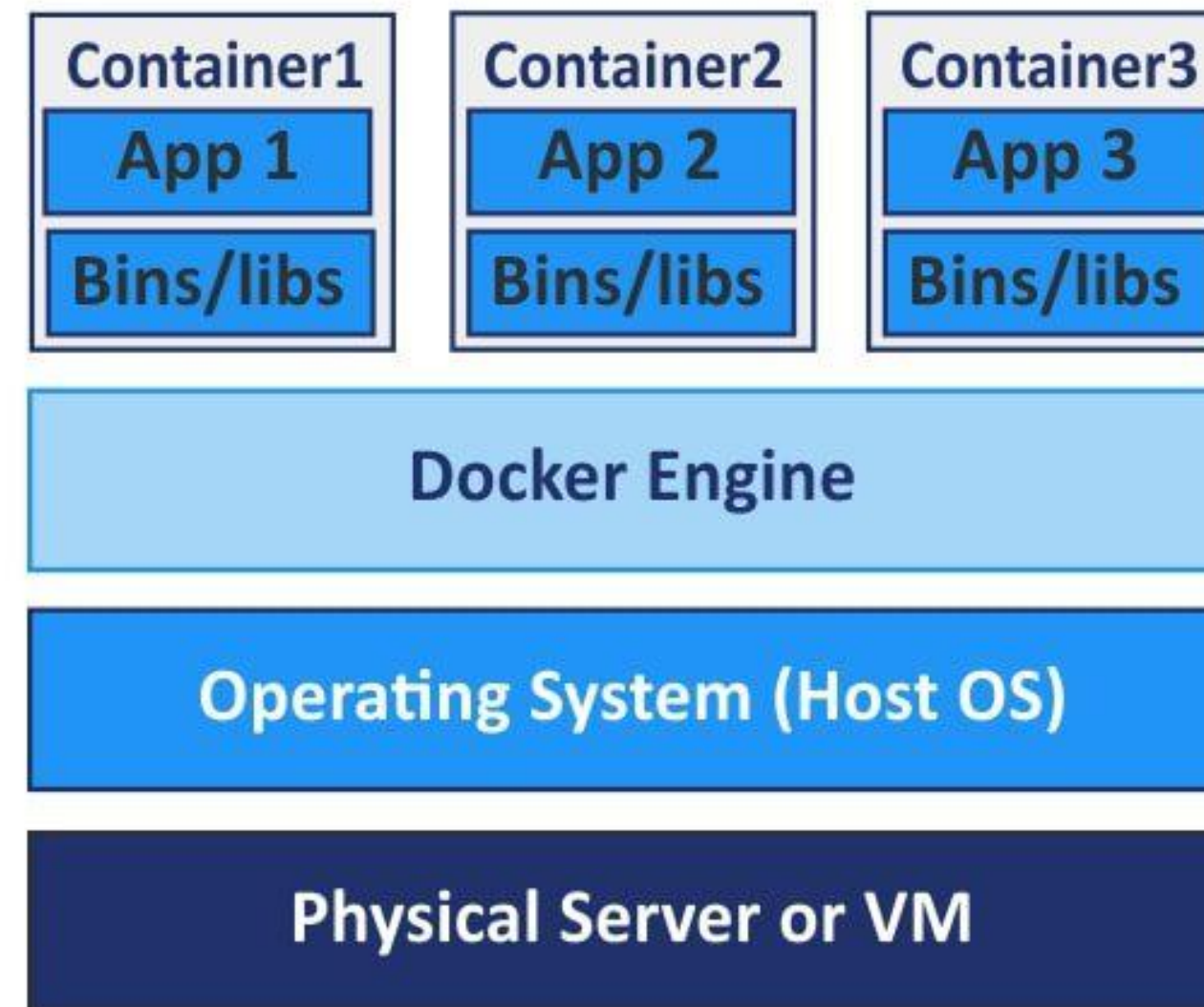
Контейнеры и DOCKER



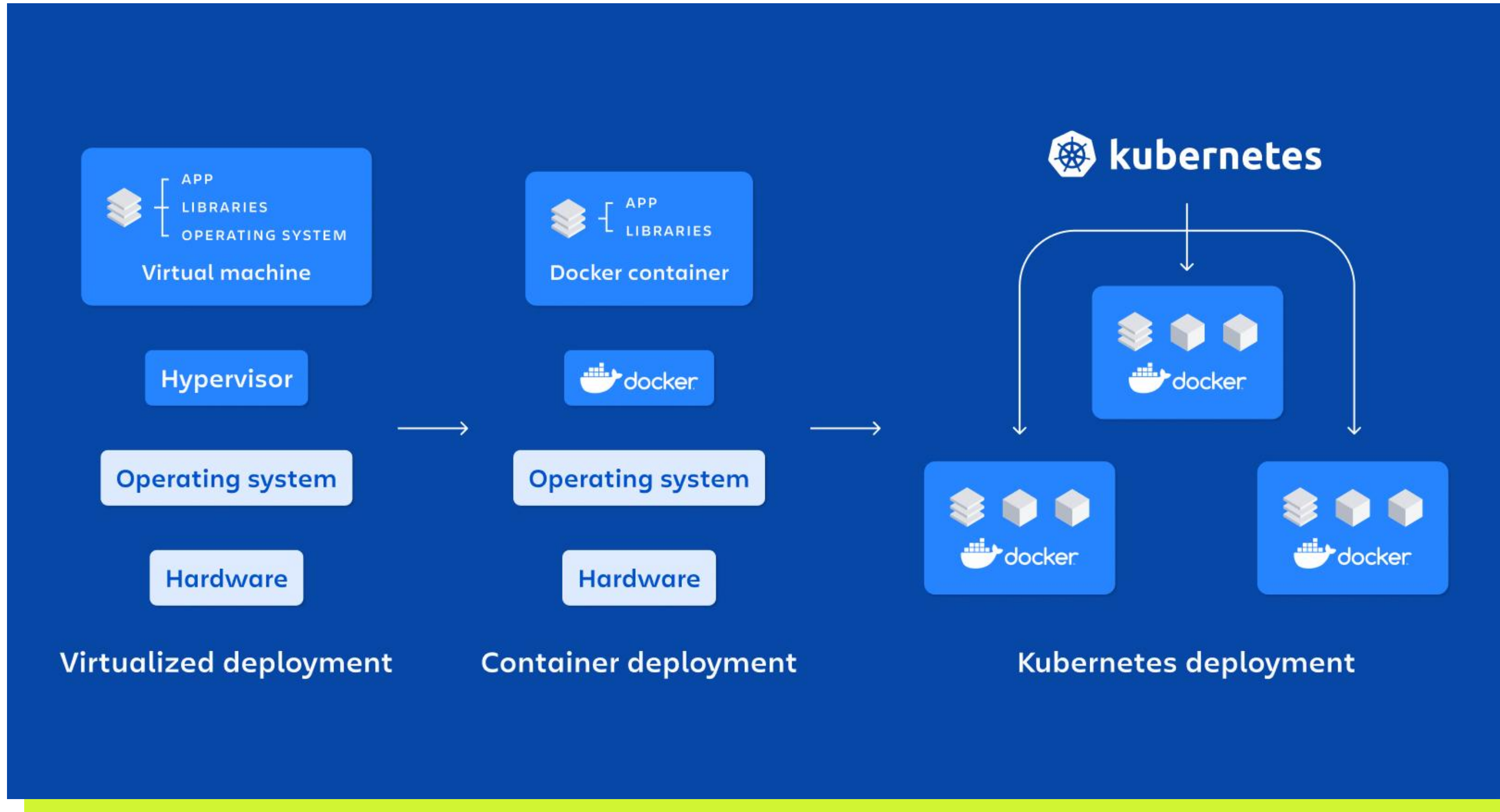
■ Virtual Machines



■ Containers



Kubernetes



Что нужно, чтобы запустить приложение в контейнере?



ПОДГОТОВИТЬ КЛАСТЕР

Создание инфраструктуры, установка и настройка оркестрации

НАПИСАТЬ K8S-МАНИФЕСТЫ

Подготовка необходимых манифестов (deployments, services, secrets, service accounts и прочее) для запуска приложения

НАПИСАТЬ DOCKERFILES

Подготовка «описания» образов контейнеров

КОНТРОЛИРОВАТЬ ПРИЛОЖЕНИЕ

Мониторинг работоспособности приложения, поиск ошибок, оптимизация и другое

СОБРАТЬ ОБРАЗЫ КОНТЕЙНЕРОВ

С использованием базовых образов формируются требуемые образы

Что может пойти не так?



ПОДГОТОВИТЬ КЛАСТЕР

Уязвимости на `node` кластера,
некорректная конфигурация K8S

НАПИСАТЬ K8S-МАНИФЕСТЫ

Повышенные привилегии у контейнеров,
секреты в открытом виде и подобное

НАПИСАТЬ DOCKERFILES

Dockerfile не соответствуют
требованиям по ИБ

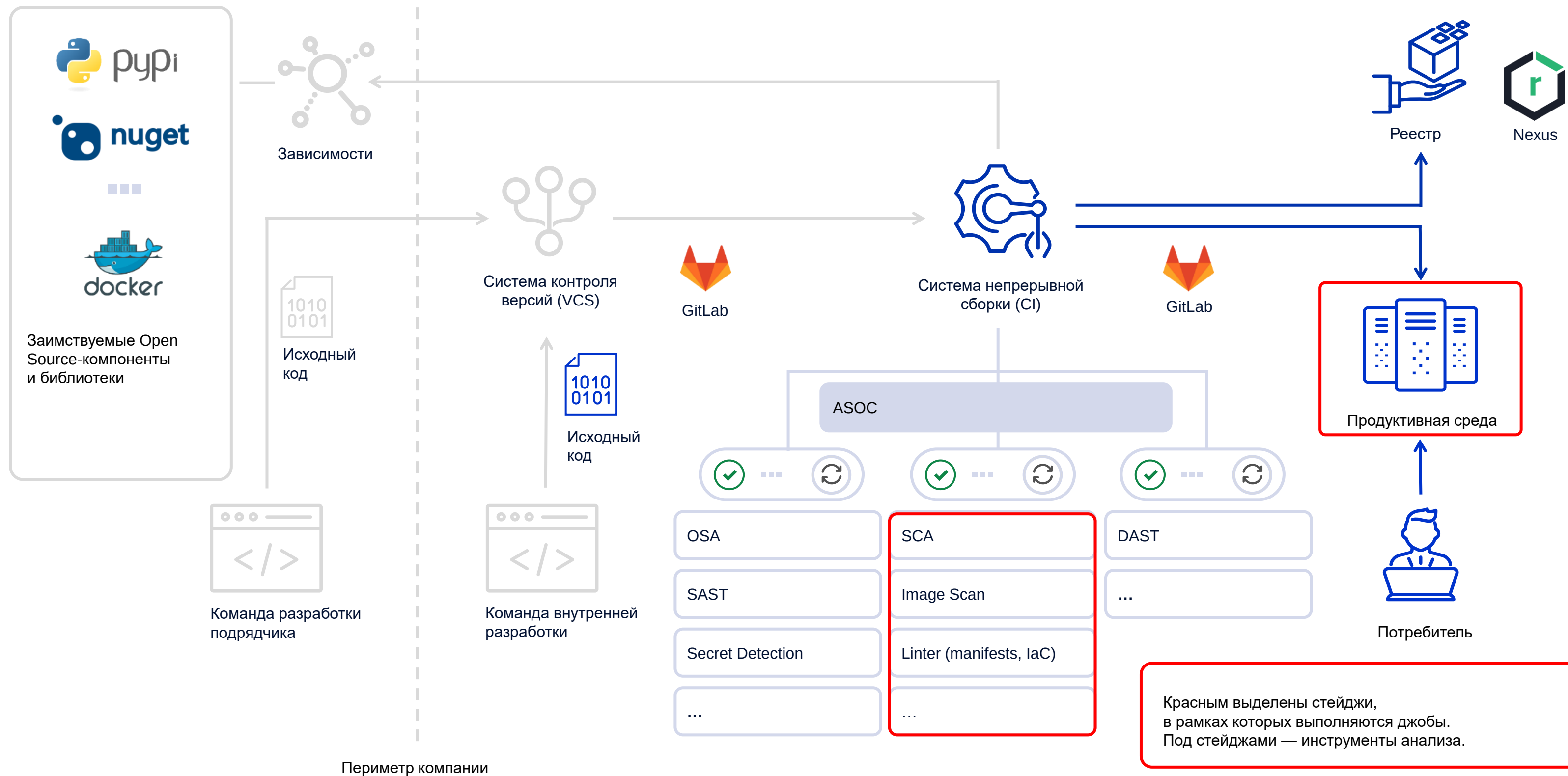
КОНТРОЛИРОВАТЬ ПРИЛОЖЕНИЕ

Эксплуатация уязвимостей в запущенном
контейнере из-за недостаточного контроля

СОБРАТЬ ОБРАЗЫ КОНТЕЙНЕРОВ

Уязвимости и вредоносное ПО
в образах контейнеров

Процесс разработки приложения. SecOps



Зачем нужен SecOps



■ ЗАДАЧИ SECOPS:

анализ образов контейнеров и их защиты в runtime (при работе в продуктиве)

ТЕМ САМЫМ ОБЕСПЕЧИВАЮТСЯ:

■ Предотвращение использования небезопасных образов контейнеров в продуктиве

■ Защита от несанкционированного доступа к контейнерам

■ Предотвращение нелегитимного взаимодействия между контейнерами

Основы DevSecOps



■

Люди

Основы DevSecOps



Люди

The diagram consists of two adjacent blue rectangular boxes. The left box is labeled "Люди" (People) and the right box is labeled "Процессы" (Processes). Above the top-left corner of the "Люди" box is a small yellow square. Above the top-left corner of the "Процессы" box is another small yellow square. A vertical blue line separates the two boxes.

Процессы

Основы DevSecOps



Люди

Процессы

Инструменты

Основы DevSecOps



Люди

- Нанимаем
- Обучаем
- Заботимся



■ Процессы

- 56 документов в ГОСТ 56939-2024
- 15 документов в DevSecOps Assessment Framework



Инструменты

- Open source Enterprise
- SAST, DAST, OSA\SCA, Container sec, ASOC\ASPM, Secret management...

Наиболее распространенные инструменты



Инструменты Secret Detection: управление секретами

Ищут в исходном коде приложения
секреты (логины, пароли, токены,
SSH-ключи и подобное)

Enterprise



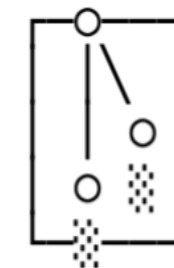
Application Inspector



Solar appScreener



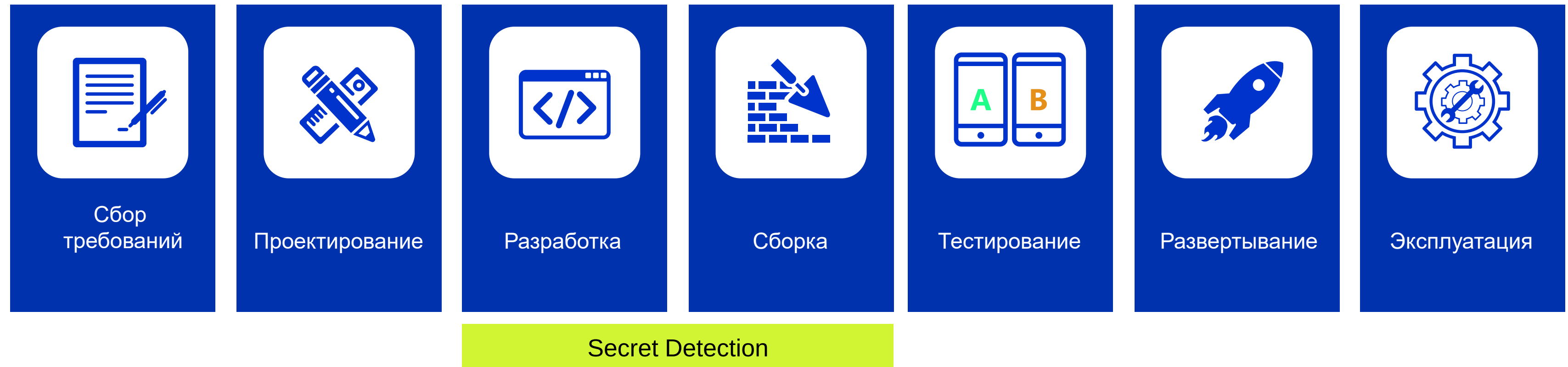
Open Source



Gitleaks



Где это может использоваться



Наиболее распространенные инструменты



Инструменты SAST: анализ исходного кода (текста)

SAST (Static Application Security Testing) — статический анализ исходного кода, поиск участков, содержащих потенциальные уязвимости.

Такой подход не требует наличия работающей сборки программы, позволяет обнаружить ошибки на раннем этапе жизненного цикла приложения и тем самым сэкономить время и деньги.

Инструменты SAST выполняют разные типы анализа — Pattern-matching, Taint, символьные вычисления и другие.

Enterprise



Application Inspector



Svace



Solar appScreener



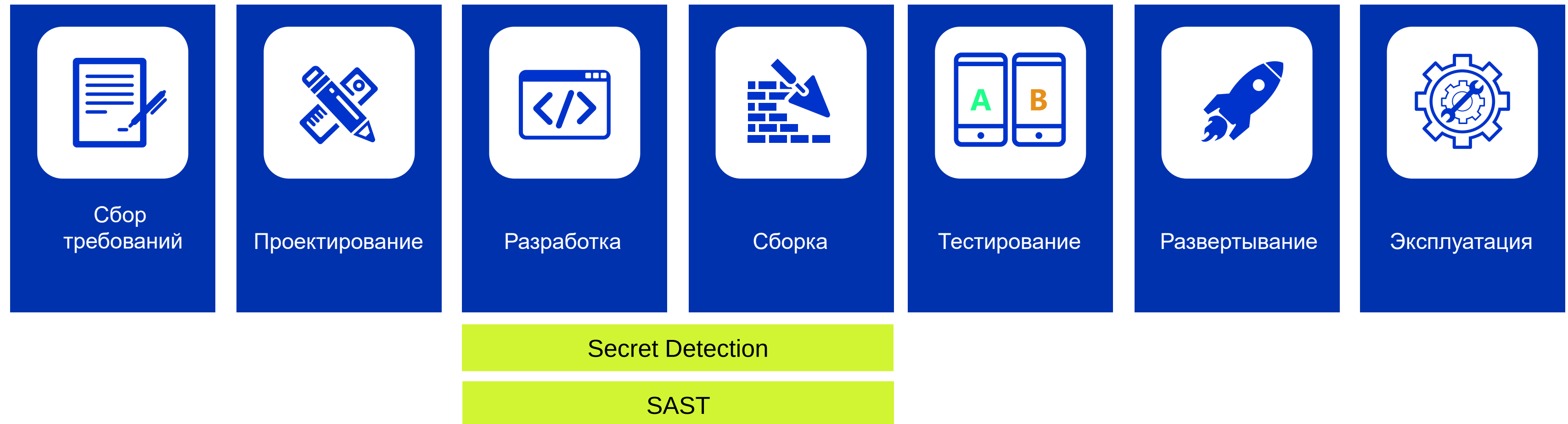
Open Source



CodeQL



Где это может использоваться



Наиболее распространенные инструменты



Инструменты DAST: анализ собранного кода (готового приложения)

Средства DAST (Dynamic Application Security Testing) выполняют динамический анализ собранного приложения. Они проводят автоматическое сканирование, имитируя вредоносную атаку с попыткой эксплуатации распространенных уязвимостей. Их задача — обнаружить незапланированные результаты раньше, чем это сделают злоумышленники.

Чтобы обнаружить уязвимости, средства DAST проверяют все точки доступа по HTTP, моделируют случайные действия и работу пользователей.

Enterprise



Blackbox



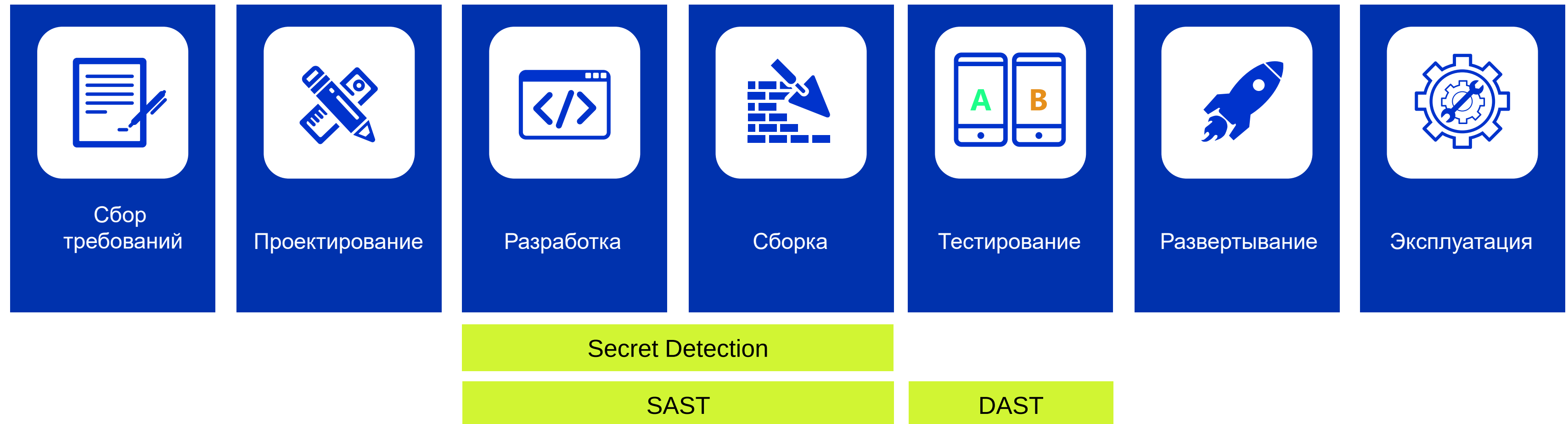
Solar appScreener



Open Source



Где это может использоваться



Наиболее распространенные инструменты



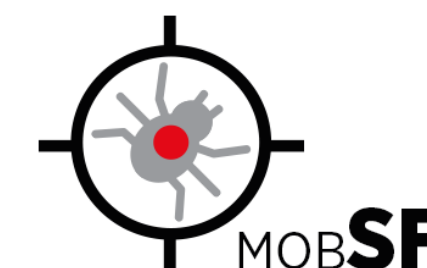
Инструменты MAST:
анализ и исходного кода,
и собранного мобильного
(готового) приложения

Средства MAST
(Mobile Application Security Testing)

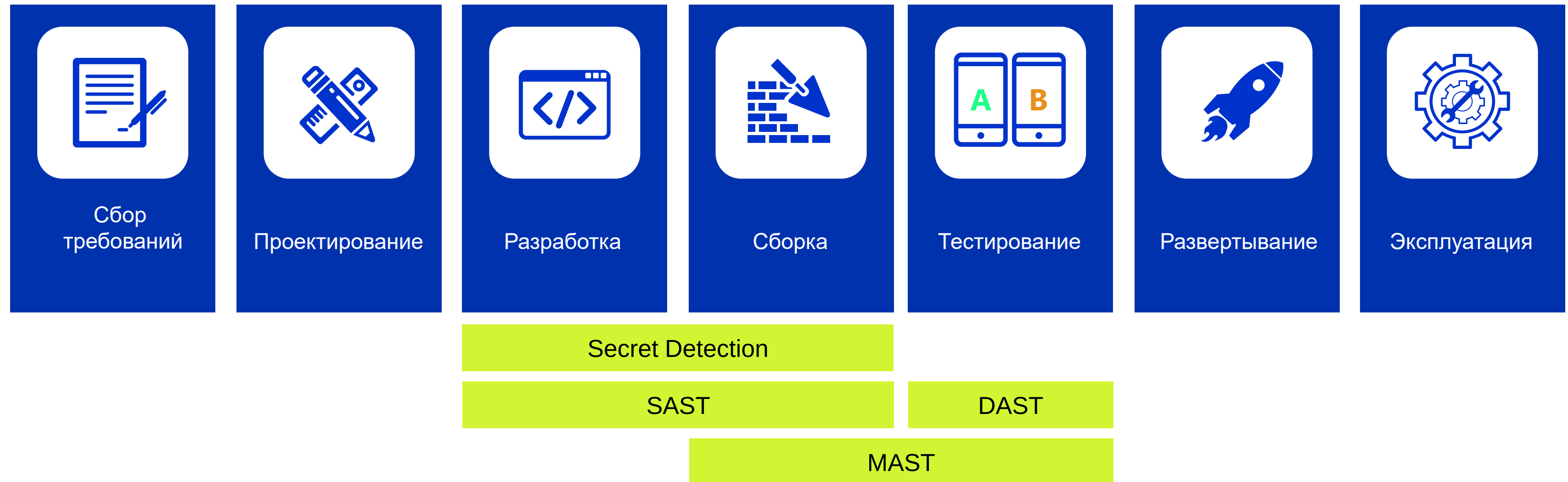
Enterprise



Open Source



Где это может использоваться



Наиболее распространенные инструменты



Инструменты SCA: композиционный анализ кода

SCA (Software Composition Analysis) — анализ компонентов приложения (какие Open Source-компоненты и библиотеки применялись при разработке) и выявление в них известных уязвимостей. Средства SCA также могут определять лицензию, под которой распространяется конкретный компонент приложения: это позволяет оценить юридические риски его использования.

Инструменты OSA: анализ Open Source-компонентов

OSA (Open Source Analysis) — анализ компонентов приложения, имеющих открытый исходный код, и формирование их списка (SBOM, Software Bill of Materials).

Enterprise

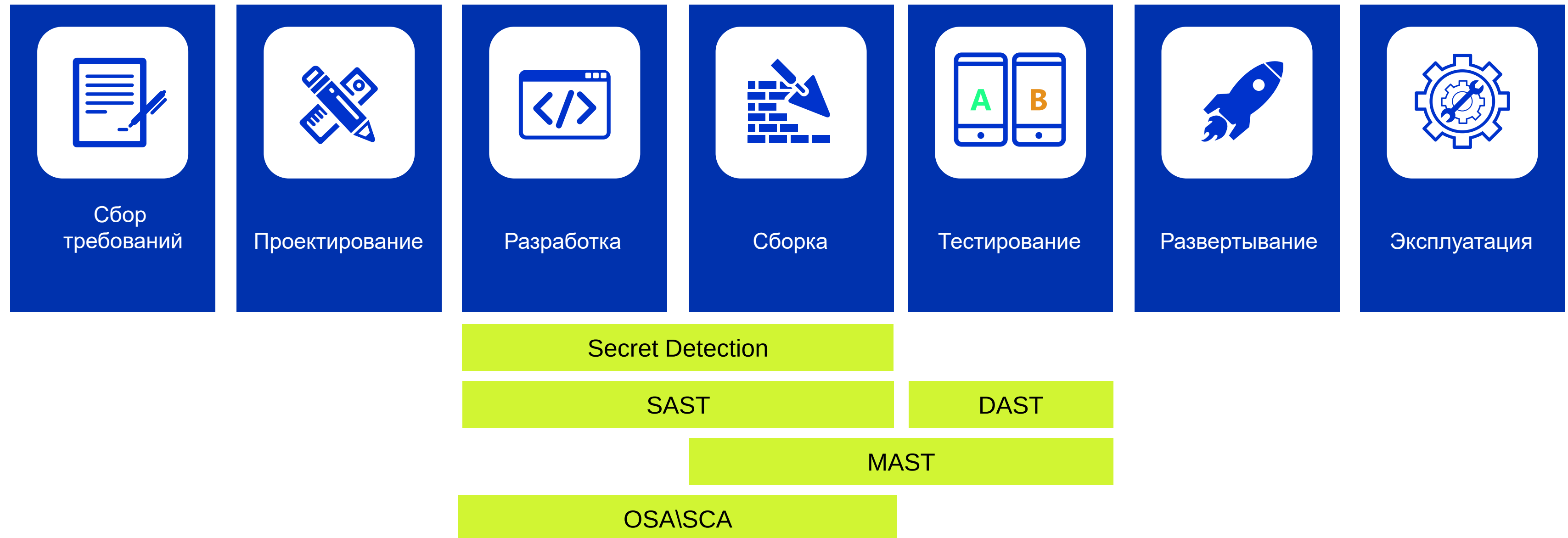


Solar appScener

Open Source



Где это может использоваться



Наиболее распространенные инструменты



Инструменты ASOC/ASPM: управление инструментами DevSec

ASOC (Application Security Orchestration and Correlation) или ASPM (Application Security Posture Management) — решения для управления процессами безопасной разработки. Они интегрируют и координируют действия разных инструментов AppSec (SAST, DAST, OSA/SCA, Secret Detection и других), позволяют собрать формируемые ими отчеты и удалить дубликаты полученных данных.

Enterprise



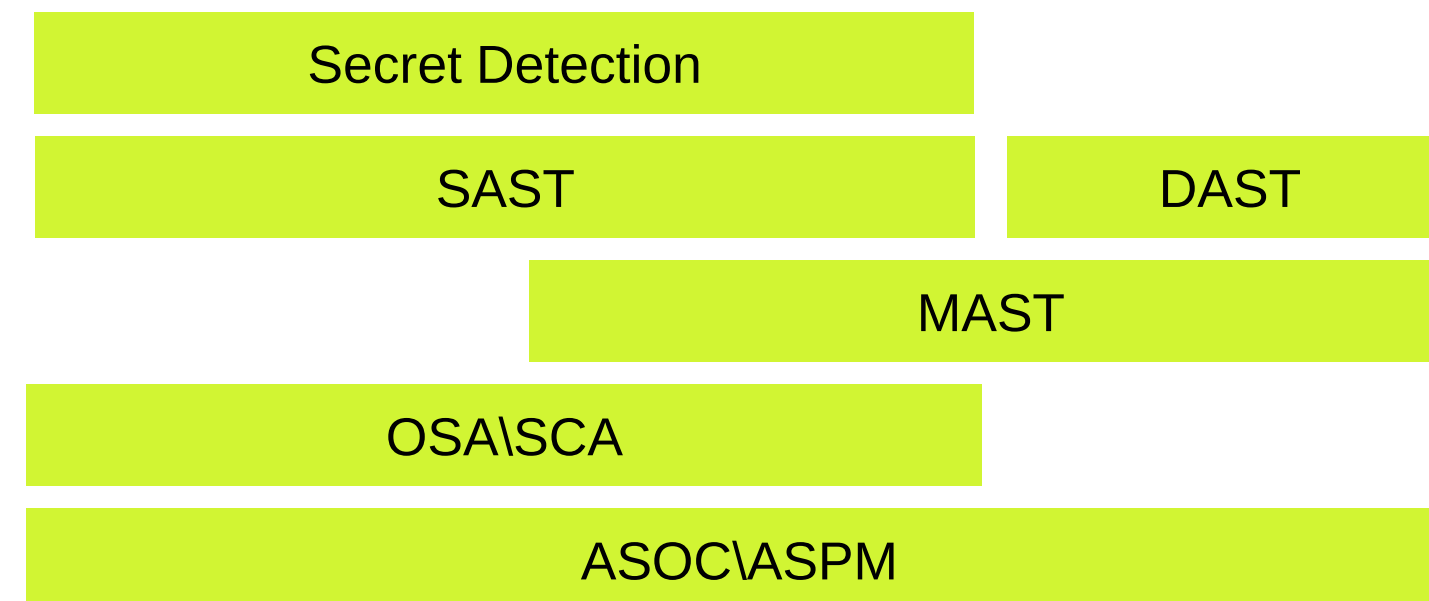
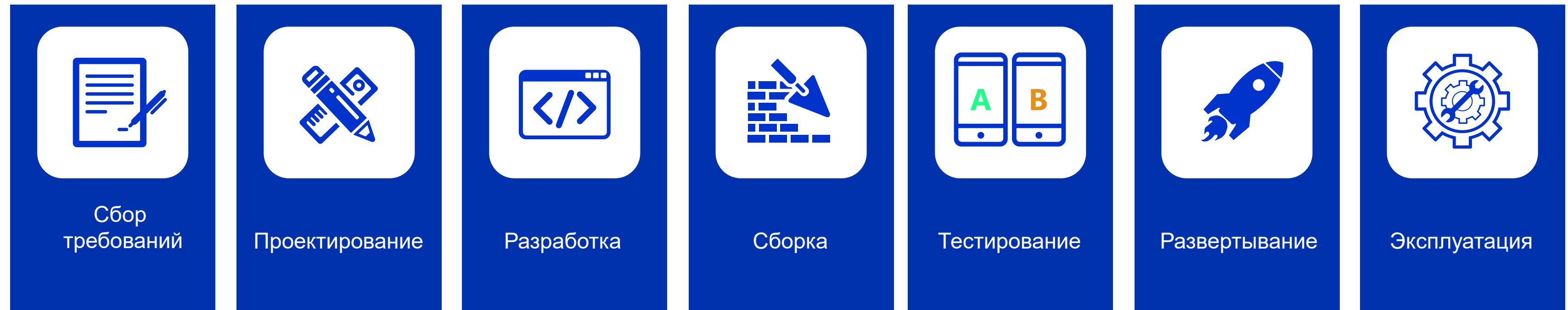
APPSEC HUB



Open Source



Где это может использоваться



Наиболее распространенные инструменты



Защита контейнеров (Container Security)

- Сканирование уязвимостей: проверка образов контейнеров на наличие известных уязвимостей в используемых ПО и библиотеках
- Контроль доступа: управление правами доступа к контейнерам и ресурсам для предотвращения несанкционированного доступа
- Мониторинг и обнаружение аномалий: непрерывный мониторинг запущенных контейнеров на предмет подозрительной активности или аномалий, которые могут указывать на атаки или компрометацию
- Контроль взаимодействия контейнеров: фильтрация сетевого трафика между контейнерами с целью ограничить их взаимодействие и минимизировать риски
- Изоляция процессов: использование технологий изоляции для предотвращения взаимодействия между контейнерами и обеспечения безопасности приложений
- Интеграция с CI/CD: внедрение практик безопасности на этапе разработки и развертывания с целью выявить уязвимости до запуска контейнеров в производственной среде

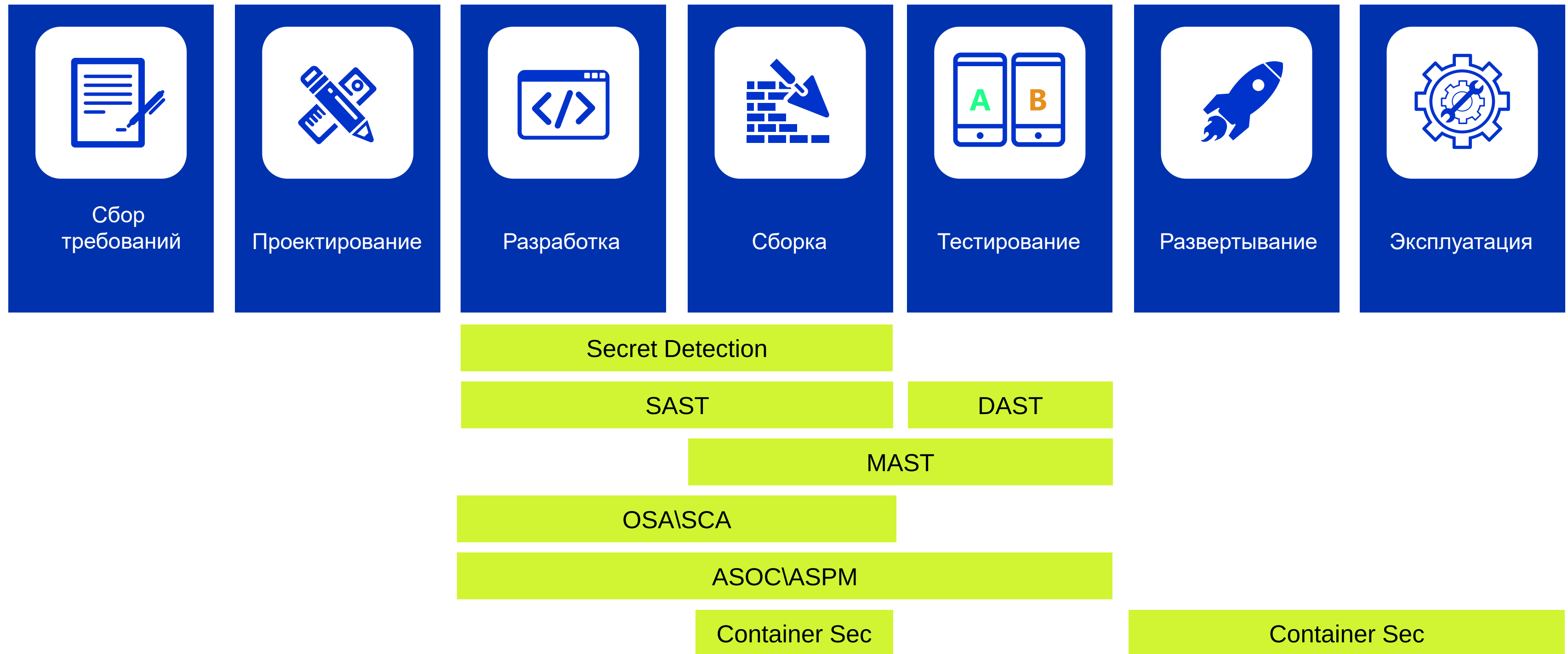
Enterprise



Open Source



Где это может использоваться



Наиболее распространенные инструменты



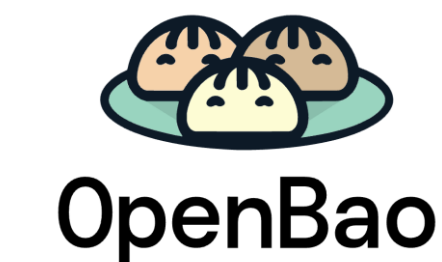
Управление секретами (Secret Management)

- Управление секретами: хранение конфиденциальных данных (пароли, API-ключи, сертификаты и другое) и управление ими
- Динамическое создание секретов: генерация временных учетных данных (например, паролей или токенов) для доступа к базам данных и другим сервисам по запросу
- Контроль доступа: настройка политик управления доступом к секретам и данным
- Аудит и логирование: ведение журналов всех операций с секретами для обеспечения прозрачности и проведения аудита
- Интеграция с системами аутентификации: поддержка разных методов аутентификации, таких как LDAP
- Хранение сертификатов и управление ими: управление TLS-сертификатами и автоматизация их выдачи и обновления
- Секреты в контейнерах: безопасная интеграция с контейнеризованными приложениями, позволяющая им получать доступ к секретам без жесткого кодирования
- Обновление и ротация секретов: автоматизация процесса ротации секретов для повышения безопасности

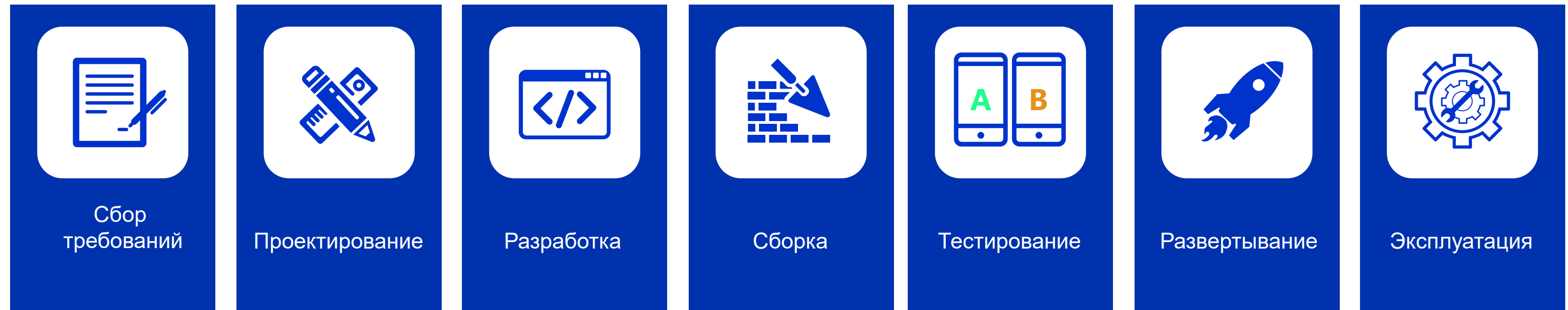
Enterprise



Open Source



Где это может использоваться





Инфосистемы
Джет

С ЧЕГО НАЧИНАТЬ
ВЫСТРАИВАТЬ ПРОЦЕССЫ
БЕЗОПАСНОЙ РАЗРАБОТКИ И
ИНФРАСТРУКТУРУ DEVSECOPS

Что надо анализировать и защищать?



[01] КОМПОНЕНТЫ

Анализ ПО во время разработки и устранение ИБ-дефектов

[02] ОКРУЖЕНИЕ РАЗРАБОТКИ

Безопасная настройка ИС, используемых для автоматизации процесса разработки

[03] СРЕДА ЭКСПЛУАТАЦИИ

Контроль настроек информационной безопасности и средств защиты в среде эксплуатации

[04] ПРИЛОЖЕНИЕ

Контроль настроек информационной безопасности и средств защиты в среде эксплуатации

Что надо анализировать и защищать?



[01] КОМПОНЕНТЫ

Анализ ПО во время
разработки и устранение
ИБ-дефектов

[02] ОКРУЖЕНИЕ РАЗРАБОТКИ

Безопасная настройка ИС,
используемых
для автоматизации процесса
разработки

[03] СРЕДА ЭКСПЛУАТАЦИИ

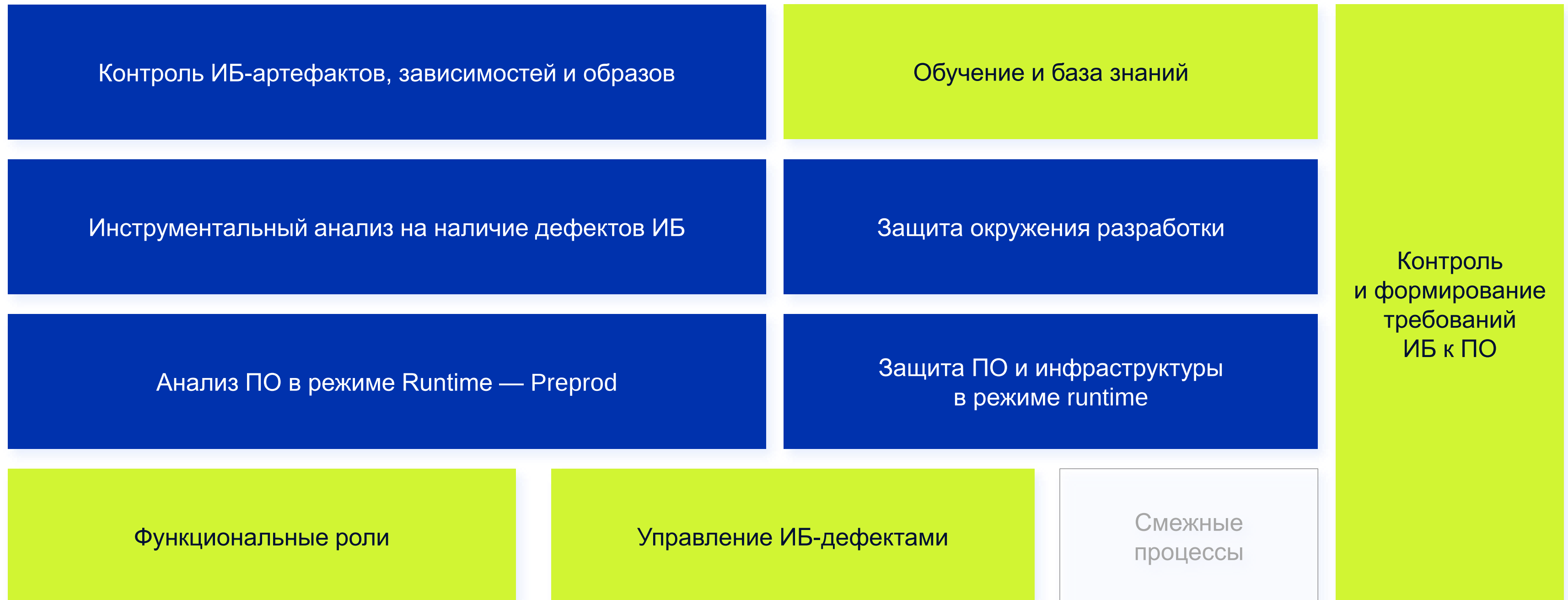
Контроль настроек
информационной
безопасности и средств
защиты в среде эксплуатации

[04] ПРИЛОЖЕНИЕ

Контроль настроек
информационной
безопасности и средств
защиты в среде эксплуатации



Общий взгляд на DEVSECOPS*

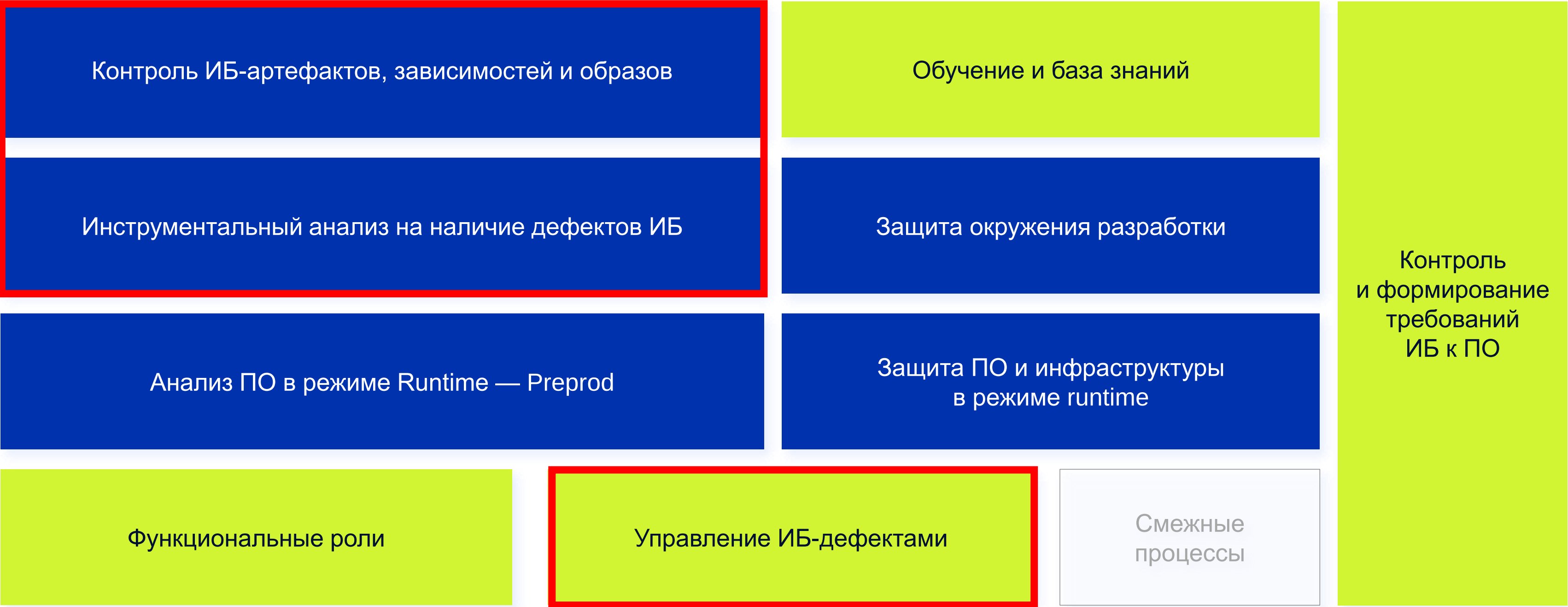


Xxx Уклон в технику **Xxx** Уклон в процессы

*<https://github.com/jet-security-team/devsecops-assessment-framework>

С чего начать. Компоненты.

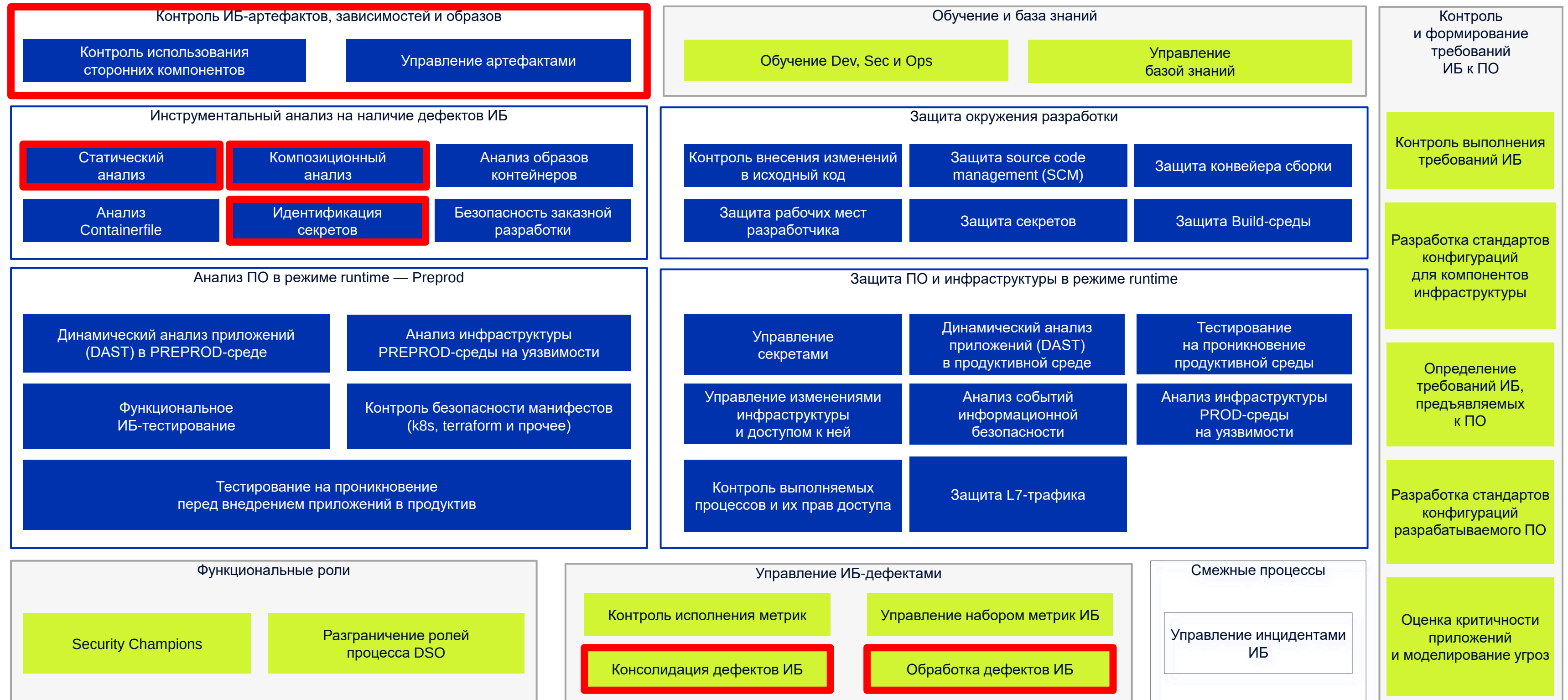
Анализ ПО во время разработки и устранение ИБ-дефектов



Xxx Уклон в технику **Xxx** Уклон в процессы

**<https://github.com/jet-security-team/devsecops-assessment-framework>*

С чего начать. Компоненты. Анализ ПО во время разработки и устранение ИБ-дефектов. Детали



КАК НАЧАТЬ?

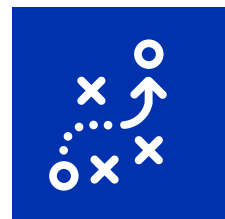
Что делать



Аудит существующих процессов и инфраструктуры разработки



Формирование дорожной карты развития безопасной разработки



Внедрение инструментов анализа ПО во время разработки

Каким способом делать

Экспертный аудит по фреймворку DAF*

Внедрение инструментов классов **SAST** и **OSA\SCA**



Инфосистемы
Джет

**СПАСИБО
ЗА ВНИМАНИЕ!**

Антон Конопак

ae.konopak@jet.su
tg @AntonyKa

2026



JET CONTAINER
SECURITY
FRAMEWORK



DEVSECOPS
ASSESSMENT
FRAMEWORK